

מעבדה 01 — מדיניות סיסמאות עם GPO

Password Policy via Group Policy — בקרת סיסמאות בדומיין מקצה לקצה

רמת קושי: ★ מתחילים

זמן משוער: 30 דקות

מודול 5 — ניהול מערכות ושירותים

[הבא ← מעבדה 02: WSUS](#)

[→ חזור למעבדה 00: AD Setup](#)

מטרות הלמידה

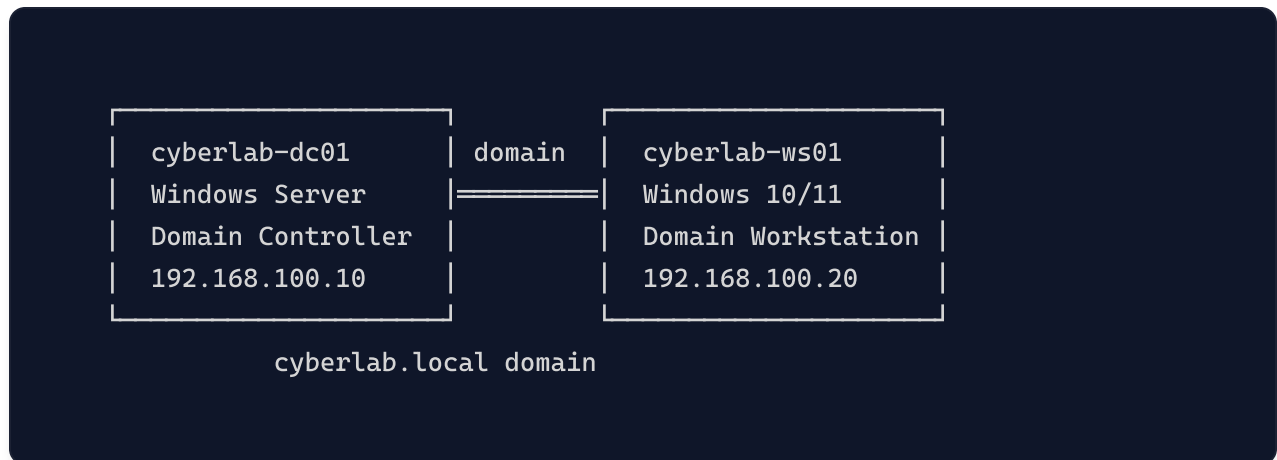
- להבין מה זה GPO ולמה הוא שולט במאות מחשבים בו-זמנית מנקודה אחת
- לפתוח את **Group Policy Management Console (GPMC)** ולנווט בו
- להגדיר מדיניות סיסמאות (אורך, מורכבות, היסטוריה, גיל מקסימלי)
- לקשר GPO לדומיין כולו ולוודא שהוא מופעל
- לאלץ רענון מדיניות בעמדת קצה ולוודא שהמדיניות נקלטה
- לראות מה קורה כשמשתמש מנסה לבחור סיסמה שמפרה את המדיניות

למה המעבדה הזו חשובה

סיסמה חלשה = חשבון פרוץ. מדיניות סיסמאות טובה מורידה את הסיכוי שתוקף יצליח לפצח חשבון משתמש דרך Brute Force או Password Spraying — שתי השיטות הראשונות שכל תוקף מנסה לפני שעוברים לטכניקות מתקדמות. אבל הצבת מדיניות בכל מחשב בנפרד = בלתי אפשרי. **GPO** הוא הכלי שמאפשר לכפות מדיניות אחת על אלפי מחשבים בו-זמנית מבקר הדומיין. אחרי המעבדה הזו תדעו לעשות את זה.

🤔 **עצרו וחשבו:** לפני שמתחילים — נחשו: כמה זמן לוקח ל-Hashcat לפצח סיסמה של 6 תווים בלבד באותיות קטנות (NTLM hash) על GPU סטנדרטי? תשובה: פחות משנייה. מה לדעתכם המינימום הסביר היום? תבדקו בסוף המעבדה.

סביבת המעבדה



מכונה	תפקיד	תיכנסו כ-
cyberlab-dc01	Domain Controller	CYBERLAB\Administrator
cyberlab-ws01	תחנת עבודה בדומיין	משתמש רגיל בדומיין (לא Admin)

📝 **הערה:** אם ה-VMs עצורות ב-VirtualBox — הפעילו אותן עכשיו: VirtualBox Manager → סמנו את שתיהן → Start. חכו 1-2 דקות עד שהן מוכנות.

דרישות מוקדמות

- ✓ **מעבדה 00 — הקמת AD** הושלמה (יש Domain Controller פעיל + WS מצורפת)
- גישה לשתי ה-VMs דרך VirtualBox (cyberlab-dc01 ו-cyberlab-ws01)

- סיסמת Domain Admin (זו שהוגדרה במעבדה 00 בעת ה-Promote)
- משתמש **student01** קיים בדומיין (נוצר בחלק ו' של מעבדה 00)
- הבנה בסיסית מה זה דומיין Active Directory (ראינו בשיעור התיאוריה)

טיפ: לפני שמתחילים — פתחו את שתי ה-VMs ב-VirtualBox. שמרו את שני החלונות פתוחים לאורך כל המעבדה. תרצו לעבור ביניהם הרבה.

טיפ: קחו snapshot עכשיו על שתי ה-VMs בשם **Pre-Lab-01**. אם משהו ישבר — חזרה תוך שניות.

חלק א' — פתיחת GPMC על בקר הדומיין (3 דקות)

1 שלב — התחברו ל-cyberlab-dc01

ב-VirtualBox Manager: דאבל-קליק על **cyberlab-dc01** כדי להעלות את חלון ה-VM. אם ה-VM כבויה — Start קודם.
במסך login: **Other user** → **CYBERLAB\Administrator** → סיסמת Domain Admin.

✓ **תוצאה צפויה:** המסך מציג Server Manager אחרי כניסה. למעלה משמאל מופיע "Dashboard" עם הודעת ברוכים הבאים.

2 שלב — פתחו את Group Policy Management

שתי דרכים — בחרו אחת:

- **דרך מהירה:** Win + R → הקלידו **gpmmc.msc** → Enter
- **דרך גרפית:** Server Manager → Tools → **Group Policy Management**

✓ **תוצאה צפויה:** נפתח חלון בשם "Group Policy Management". בעץ השמאלי

רואים `cyberlab.local` → Domains → `Forest: cyberlab.local`

⚠ **שימו לב:** אם הופיע "MMC could not create the snap-in" — אתם לא מחוברים ל-DC. ודאו שאתם ב-cyberlab-dc01, לא ב-ws01.

שלב 3 — הרחיבו את עץ הדומיין

3

בעץ השמאלי, לחצו על המשולש ליד `cyberlab.local` כדי להרחיב אתם אמורים לראות:

- תיקיית **Default Domain Policy** (ה-GPO שברירת המחדל יוצרת)
- תיקיית **Domain Controllers** (OU)
- תיקיית **Group Policy Objects** (כאן יוצרים GPOs חדשים)

🤔 **עצרו וחשבו:** הבחנתם ב-"Default Domain Policy"? זה GPO שמיקרוסופט יוצרת אוטומטית עם הקמת הדומיין. הוא כבר מכיל מדיניות סיסמאות בסיסית. אנחנו **לא** נערוך אותו — נכין GPO חדש משלנו. למה? כי שינוי ה-Default מסבך rollback ועלול לפגוע ב-AD עצמו. הכלל: לא נוגעים ב-Default Domain Policy.

חלק ב' — יצירת ה-GPO והגדרת המדיניות (12 דקות)

שלב 4 — צרו GPO חדש

1

1. בעץ השמאלי לחצו **לחיצה ימנית** על `Group Policy Objects`

2. בחרו **New**

3. בחלון שנפתח, שדה `Name`: הקלידו `Security - Password Policy`

4. שדה `Source Starter GPO`: השאירו `(none)`

5. לחצו OK

✓ **תוצאה צפויה:** ה-GPO החדש **Security - Password Policy** מופיע ברשימה תחת Group Policy Objects.

💡 **טיפ:** הקפידו על שמות עקביים: התחילו ב- **Security -** או **Network -** או **Apps -** כדי לסווג בארגון אמיתי יש מאות GPOs — בלי convention שמות מתבלבלים.

2 שלב 5 — פתחו את ה-GPO לעריכה

לחצו לחיצה ימנית על **Security - Password Policy** → **...Edit**

✓ **תוצאה צפויה:** נפתח חלון חדש: *Group Policy Management Editor*. שמאל למעלה רואים שני ענפים: **Computer Configuration** ו-**User Configuration**.

⚠ **שימו לב:** אל תסגרו את חלון GPMC הראשי. שני החלונות צריכים להישאר פתוחים — נחזור ל-GPMC בחלק ג'.

3 שלב 6 — נווטו אל מדיניות הסיסמאות

בעץ השמאלי של ה-Editor, פתחו את הדרך הבאה (לחצו על המשולשים):

```

Computer Configuration
├── Policies
│   ├── Windows Settings
│       ├── Security Settings
│           ├── Account Policies
│               └── Password Policy
    
```

✓ **תוצאה צפויה:** בצד ימין מופיעות 6 הגדרות: Enforce password history,

Maximum password age, Minimum password age, Minimum password length, Password must meet complexity requirements, Store passwords using reversible encryption.

שלב 7 — Minimum password length

4

1. לחצו לחיצה כפולה על **Minimum password length**

2. סמנו **Define this policy setting**

3. הקלידו את הערך **12**

4. לחצו **OK**

✓ **תוצאה צפויה:** בעמודת ה-Policy Setting הערך השתנה מ-Not Defined ל-

12 characters

🧐 **עצרו וחשבו:** למה 12 ולא 8? NIST 800-63B (התקן האמריקאי של 2024) ממליץ על מינימום 15 לחשבונות מורשים, ו-8 כרצפה מוחלטת. 12 הוא פשרה סבירה לסביבה ארגונית — מאזן בין אבטחה לזכירות.

שלב 8 — Password must meet complexity requirements

5

1. לחצו לחיצה כפולה על **Password must meet complexity requirements**

2. סמנו **Define this policy setting**

3. בחרו **Enabled**

4. לחצו **OK**

✓ **תוצאה צפויה:** הערך השתנה ל- **Enabled**

📝 **הערה:** מה זה אומר בפועל: הסיסמה חייבת להכיל לפחות 3 מתוך 4 קטגוריות — אותיות גדולות, אותיות קטנות, ספרות, תווים מיוחדים. גם אסור שתכיל את שם

המשתמש.

שלב 9 — Maximum password age

6

1. לחצו כפול על **Maximum password age**2. סמנו **Define this policy setting**3. הקלידו **365** (סיסמה תקפה לשנה)4. לחצו **OK**✓ **תוצאה צפויה:** הערך: **365 days**

🧐 **עצרו וחשבו:** למה 365 ולא 30 או 90? NIST שינו עמדה ב-2017: כפיית שינוי תכופה מובילה משתמשים לסיסמאות גרועות יותר (→ Summer2024! → Summer2025!). מומלץ להחליף רק אם יש חשד לדליפה. 365 יום זה רף בריא.

שלב 10 — Enforce password history

7

1. לחצו כפול על **Enforce password history**2. סמנו **Define this policy setting**3. הקלידו **10** (10 סיסמאות אחרונות נחסמות לשימוש חוזר)4. לחצו **OK**✓ **תוצאה צפויה:** הערך: **10 passwords remembered****שלב 11 — סגרו את ה-Editor**

8

סגרו את חלון ה-Group Policy Management Editor. אין כפתור "Save" — שינויים נשמרים אוטומטית בכל פעם שלחצתם OK.

⚠️ **שימו לב:** אם תסגרו את ה-GPO לפני שלחצתם OK בחלון של הגדרה — השינוי יאבד. כל לחיצה על OK = שמירה. כל Cancel = ביטול.

חלק ג' — קישור ה-GPO לדומיין (3 דקות)

יצירת GPO לבד **לא** מפעילה אותו. צריך לקשר אותו (Link) ליעד — דומיין, OU, או Site. נקשר עכשיו לדומיין כולו.

1 שלב 12 — קשרו את ה-GPO לדומיין

- חזרו לחלון GPMC הראשי (אם נסגר, פתחו שוב `gpmc.msc`).
1. בעץ השמאלי, לחצו לחיצה ימנית על `cyberlab.local` (תחת Domains)
2. בחרו **Link an Existing GPO...**
3. בחלון שנפתח, בחרו `Security - Password Policy`
4. לחצו **OK**

✅ **תוצאה צפויה:** תחת `cyberlab.local` בעץ מופיע עכשיו ה-GPO `Security - Password Policy` עם אייקון של "shortcut" (חץ קטן).

🤔 **עצרו וחשבו:** למה האייקון הוא shortcut? כי GPO יושב פיזית ב-Group Policy Objects, ו-Linking הוא רק קישור (כמו symlink). אותו GPO יכול להיות מקושר למספר OUs בו-זמנית — שינוי אחד משפיע על כולם.

2 שלב 13 — אמתו שה-Link פעיל

לחצו על ה-GPO החדש בעץ. בצד ימין עוברים ללשונית **Settings**.

✓ **תוצאה צפויה:** רואים סיכום של כל ההגדרות ששינינו: 12 chars, complexity Enabled, max age 365, history 10. אם אחת מהן חסרה — חזרו לחלק ב'.

חלק ד' — אימות במחשב הקצה (8 דקות)

GPOs מתעדכנים אוטומטית כל 90-120 דקות. לא נחכה. נכפה רענון מיידי ונראה שהמדיניות עובדת.

1 שלב 14 — עברו ל-cyberlab-ws01

ב-VirtualBox Manager: דאבל-קליק על `cyberlab-ws01` (אם כבוי, Start). היכנסו עם משתמש דומיין רגיל: `CYBERLAB\student01` + הסיסמה `Student-Lab-2026!`.

⚠ **שימו לב:** לא להתחבר כ-Domain Administrator. רוצים לראות את התנהגות המדיניות מנקודת מבט של משתמש קצה רגיל.

2 שלב 15 — אלצו רענון GPO

פתחו PowerShell (Start → הקלדו `powershell`). הריצו:

```
gpupdate /force
```

✓ **תוצאה צפויה:** הפלט מסתיים ב:

```
Computer Policy update has completed successfully.
```

```
User Policy update has completed successfully.
```

⚠ **שימו לב:** אם רואים "The computer is not part of a domain" — אתם ב-DC במקום ב-WS, או שהמכונה לא בדומיין. בדקו עם `whoami /upn` — צריך להגיע ל-`...@cyberlab.local`.

שלב 16 — בדקו אילו GPOs הוחלו

3

```
gpreult /r /scope:computer
```

CLI

✅ **תוצאה צפויה:** בפלט תחת "Applied Group Policy Objects" אתם אמורים לראות:

Security - Password Policy

(לצד Default Domain Policy (וכן)

💡 **טיפ:** אם ה-GPO החדש לא מופיע — חכו 30 שניות והריצו שוב `gpupdate /force`. רפליקציה ב-AD לוקחת זמן. אם אחרי 3 ניסיונות עדיין לא — חזרו ל-DC ובדקו שה-Link מופיע על `cyberlab.local`.

שלב 17 — נסו לשנות סיסמה לחלשה (היא תיכשל)

4

בחלון ה-VM של `cyberlab-ws01`: סרגל עליון של `VirtualBox` → **Input** → **Keyboard** → **Insert Ctrl-Alt-Del** → **Change a password** → (De1 + Host) (א) **Keyboard** → **Insert Ctrl-Alt-Del** → **Change a password** → נסו את הסיסמה החלשה הבאה:

○ סיסמה ישנה: (הסיסמה הנוכחית שלכם)

○ סיסמה חדשה: `abc123`

○ אישור: `abc123`

✅ **תוצאה צפויה:** Windows דוחה: "Unable to update the password. The value provided for the new password does not meet the length, complexity, or history"

"requirements of the domain"

🤖 **עצרו וחשבו:** למה זה נכשל? `abc123` = 6 תווים בלבד (פחות מ-12), אין אותיות גדולות, אין סימנים מיוחדים. נכשל בשני חוקים בו-זמנית. המדיניות פועלת.

שלב 18 — נסו סיסמה תקפה

5

נסו שוב, הפעם עם:

◦ סיסמה חדשה: `WinterMountain2026!`

◦ אישור: `WinterMountain2026!`

✅ **תוצאה צפויה:** Windows מאשר: "Your password has been changed".

💡 **טיפ:** 19 תווים, יש Upper+lower+digit+symbol, וגם זכירה קלה (passphrase). זו סיסמה טובה.

חלק ה' — לשבור בכוונה (4 דקות)

כדי להבין באמת איך GPO עובד, נשבר אותו ונראה מה קורה.

שלב 19 — נתקו את ה-GPO זמנית

1

חזרו ל- `cyberlab-dc01` → GPMC. לחצו לחיצה ימנית על ה-GPO המקושר תחת `cyberlab.local` (שם) `Security - Password Policy` עם החץ). הסירו את הסימון מ-**Link Enabled** (זה toggle).

✅ **תוצאה צפויה:** האייקון של ה-GPO הופך אפור/דהוי בעץ.

⚠️ **שימו לב:** לא לחצנו **Delete**! הסרת Link ≠ מחיקת GPO. הסרה רק מנטרלת זמנית. מחיקה היא בלתי הפיכה.

2 שלב 20 — רענונו ב-WS ובדקו

2

חזרו ל-PowerShell → cyberlab-ws01:

```
gpupdate /force  
gpresult /r /scope:computer
```

CLI

✅ **תוצאה צפויה:** ה-GPO Security - Password Policy כבר לא מופיע ברשימת "Applied". הוא נוטרל.

🤖 **עצרו וחשבו:** בלי לכפות רענון — כמה זמן זה היה לוקח להתעדכן? 90-120 דקות. בארגון של אלפי תחנות, זה אומר שינויים מתפזרים בהדרגה. בעת חירום (פגיעה פעילה) צריך להריץ `gpupdate /force` בסקריפט במקביל על כל התחנות.

3 שלב 21 — החזירו את ה-Link

3

חזרו ל-GPMC → DC → לחצו ימני על ה-GPO המקושר → **Link Enabled** (החזירו את הסימון).
חזרו ל-WS → `gpupdate /force` . ה-GPO חזר.

אתגרי בונוס

אתגר בונוס: בונוס 1 — Account Lockout. ב-GPO החדש, נווטו אל *Account Policies* → *Account Lockout Policy*. הגדירו **Account lockout threshold** ל-5 ניסיונות. מה זה אומר ולמה זה חשוב? (תשובה: אחרי 5 כשלי כניסה ברצף, החשבון ננעל. עוצר Brute Force ו-Password Spraying).

אתגר בונוס: בונוס 2 — Fine-Grained Password Policy. חיפשו ב-Google "PSO Fine-Grained Password Policy". מתי הייתם משתמשים ב-PSO במקום ב-GPO רגיל? (תשובה: כש-Group Admins צריכים מדיניות חמורה יותר ממשתמשים רגילים. PSO מאפשר חוקים שונים לקבוצות שונות באותו דומיין).

אתגר בונוס: בונוס 3 — gpresult /h. הריצו `gpresult /h C:\report.html` ב-ws01, פתחו את הקובץ ב-Edge. מה רואים שם שלא ראיתם ב-`gpresult /r`? (רמז: הירכיה ויזואלית של GPOs, יחד עם זמני עיבוד).

אתגר בונוס: בונוס 4 — סדר העיבוד LSDOU. חפשו את ראשי התיבות LSDOU. ה-GPO שיצרנו קושר לדומיין (D). אם אותה הגדרה מופיעה ב-Default Domain Policy וגם ב-GPO שלנו עם ערכים שונים — מי ינצח? (תשובה: GPO עם Link Order נמוך יותר ינצח. בודקים ב-GPMC → לוחצים על cyberlab.local → לשונית "Linked Group Policy Objects" → עמודת "Link Order").

צ'ק-ליסט אימות — סיימתם אם:

- ☐ ה-GPO **Security - Password Policy** קיים תחת Group Policy Objects
- ☐ ה-GPO מקושר ל-**cyberlab.local** (לא ל-OU בלבד)
- ☐ ב-ws01 מציג את ה-GPO תחת "Applied" `gpresult /r`
- ☐ ניסיון לשים סיסמה **abc123** נכשל
- ☐ סיסמה חזקה כמו **WinterMountain2026!** מתקבלת
- ☐ הסרת ה-Link → רענון → ה-GPO לא מופיע ב-Applied. הוספה חוזרת → חוזר.

עיקרי הדברים

- GPO = הדרך לכפות הגדרות על אלפי מחשבים מנקודה אחת. בלי GPO = ניהול ידני. עם GPO = ניהול מרוכז.
- יצירת GPO ≠ הפעלת GPO. צריך לקשר (Link) ליעד (דומיין/Site/OU).
- Default Domain Policy = לא נוגעים בו. יוצרים GPOs נפרדים לפי תפקיד.
- Computer Configuration → Windows Settings → Security Settings → Account Policies → Password Policy
- `gpupdate /force` = רענון מיידי. `gpresult /r` = הראה לי מה הוחל.
- ארבעת הברגים של מדיניות סיסמאות: Length (אורך), Complexity (מורכבות), History (היסטוריה), Max Age (גיל מקסימלי). ארבעתם יחד = הגנה הגיונית. רק חלק מהם = פרצות.
- NIST 2024: 12-15 תווים מינימום, complexity, החלפה רק בעת חשד. לא כל 30 יום.

✓ **תוצאה צפויה:** סיימתם את היסוד. במעבדה הבאה (WSUS) נראה איך לשמור את אותם 1000 מחשבים מעודכנים אוטומטית.

בסוף המעבדה — snapshot + כיבוי

1. קחו snapshot של שתי ה-VMs בשם `Post-Lab-01-PasswordPolicy` — שמירת מצב טוב לאחר שעבד
2. כיבוי תקין: ב-WS תחילה (`shutdown /s /t 0`) → אז ב-DC
3. אז: סגרו את חלון ה-**Send the shutdown signal** → VM

💡 **טיפ:** snapshot בסיום מעבדה = פוליסת ביטוח. אם הסבב הבא של מעבדות יהרוס משהו — תוכלו לחזור בדיוק לכאן.

הבא ← מעבדה 02: WSUS

→ חזור למעבדה 00: AD Setup

29/04/2026 · 01 מעבדה · מערכות ושירותים — 5 חודול · CyberLabs ©